Politechnika Krakowska
im. Tadeusza Kościuszki

Wydział Informatyki i Matematyki

Wiktor Zmiendak

Numer albumu: 142706

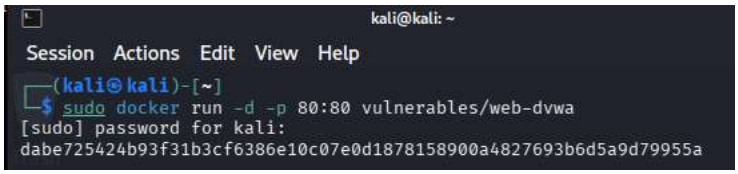
Sprawozdanie

Bezpieczeństwo aplikacji internetowych

Laboratorium nr 10

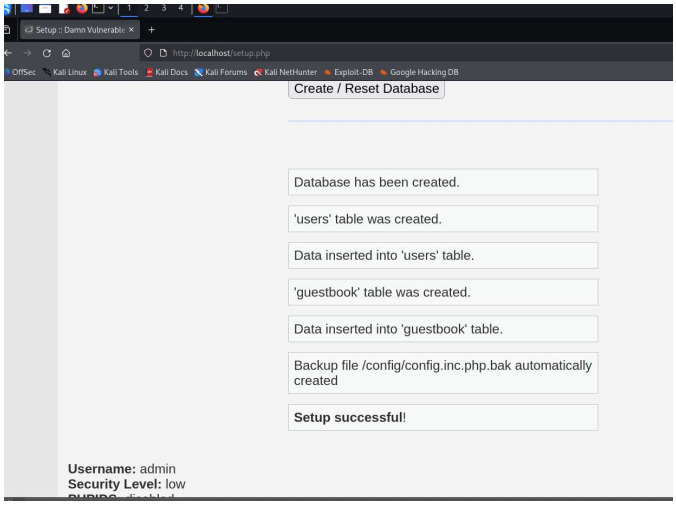
Zadanie 2

Odpalamy kontener web-dvwa



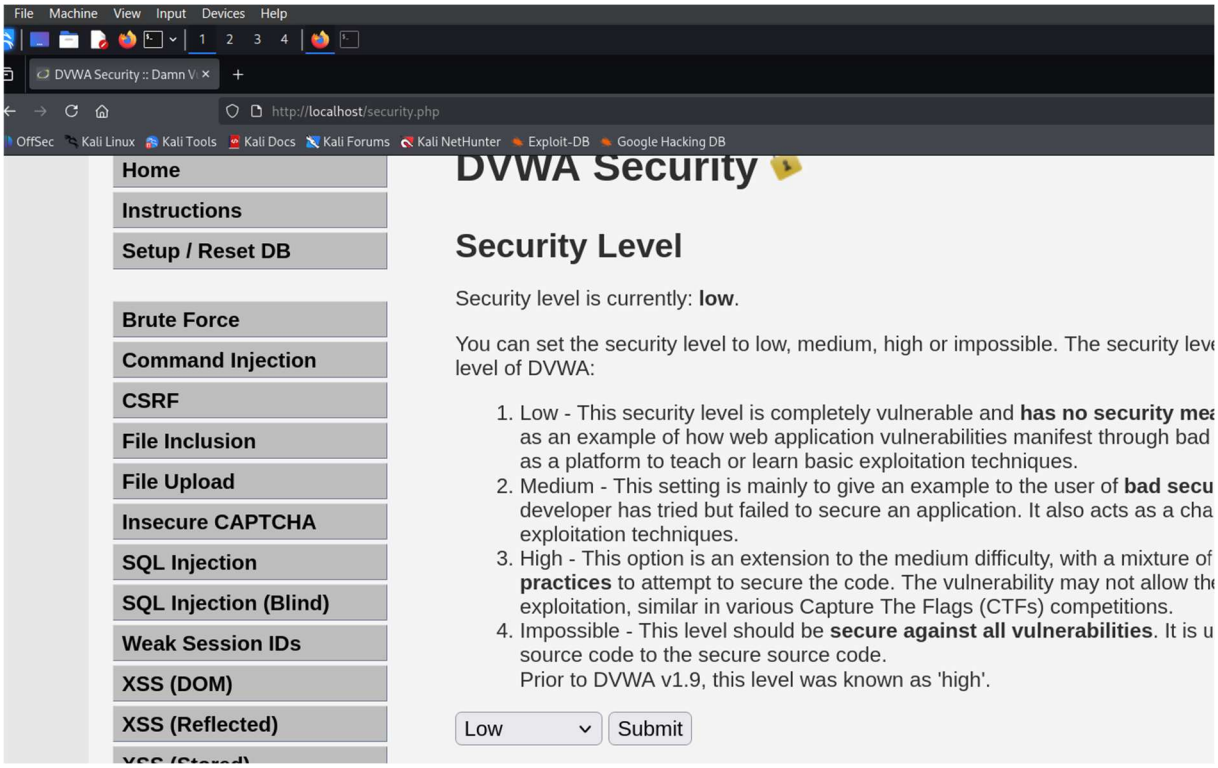
Zadanie 3

Logujemy się do serwisu i tworzymy bazę danych

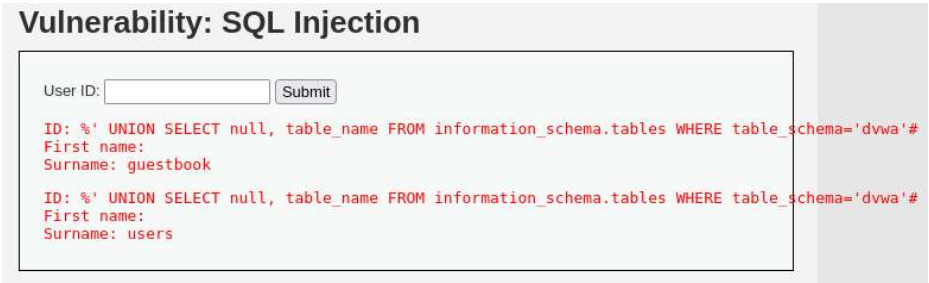


Zadanie 4

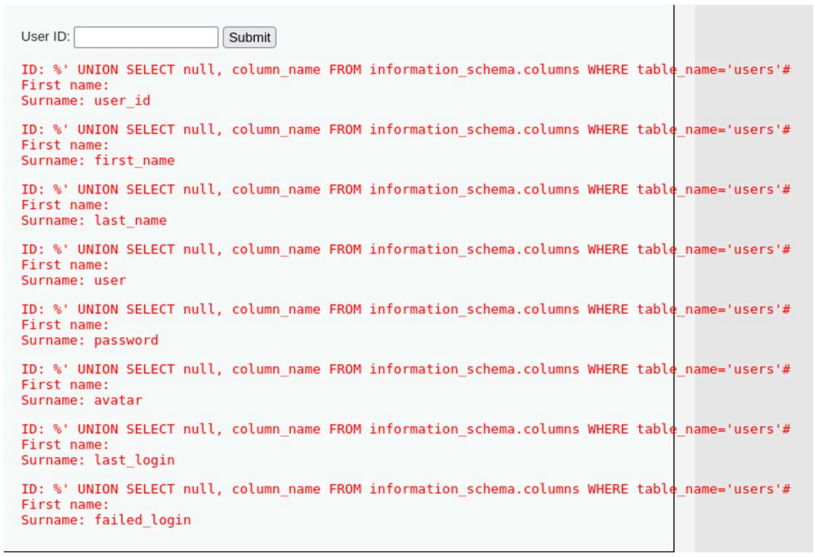
Ustawiamy poziom zabezpieczeń na „low” i przechodzimy do zakładki SQL Injection



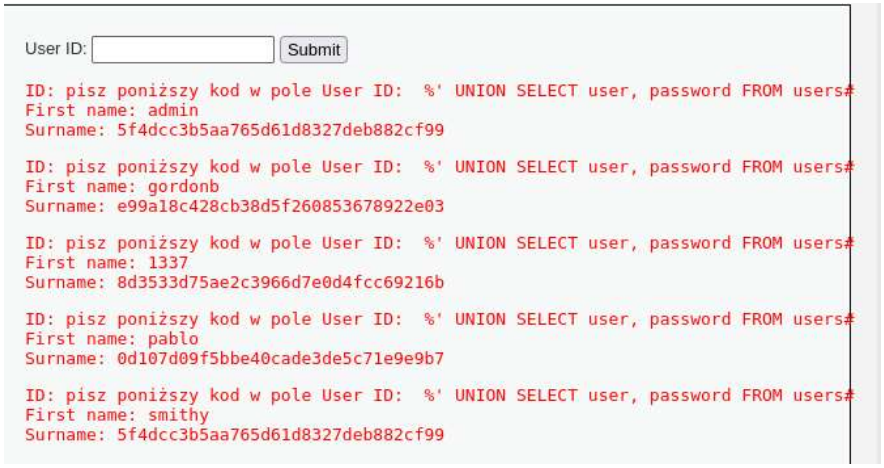
Naszym zadaniem jest wyciągnąć haseł użytkowników posługując się formularzem na stronie. Pierwszą rzeczą którą możemy sprawdzić są dostępne tablice z danymi. Robimy to przy pomocy zwykłego polecenia z SELECT - *%' UNION SELECT null, table_name FROM information_schema.tables WHERE table_schema='dvwa'#*



Naszą uwagę przyciąga tablica users dlatego postanawiamy wypisać jej kolumny przy pomocy polecenia - *%' UNION SELECT null, column_name FROM information_schema.columns WHERE table_name='users'#*



Teraz gdy wiemy jakie skrywa ona kolumny możemy wypisać ich zawartość przy pomocy - *%' UNION SELECT user, password FROM users#*



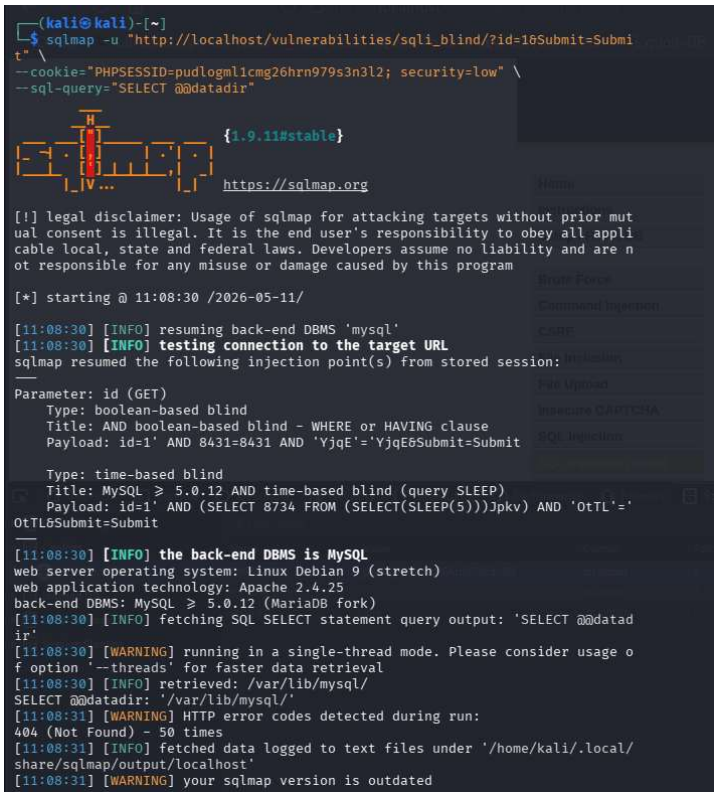
Hasła są zahashowane jednak możemy je złamać wpisując je przykładowo na stronie CrackStation.net



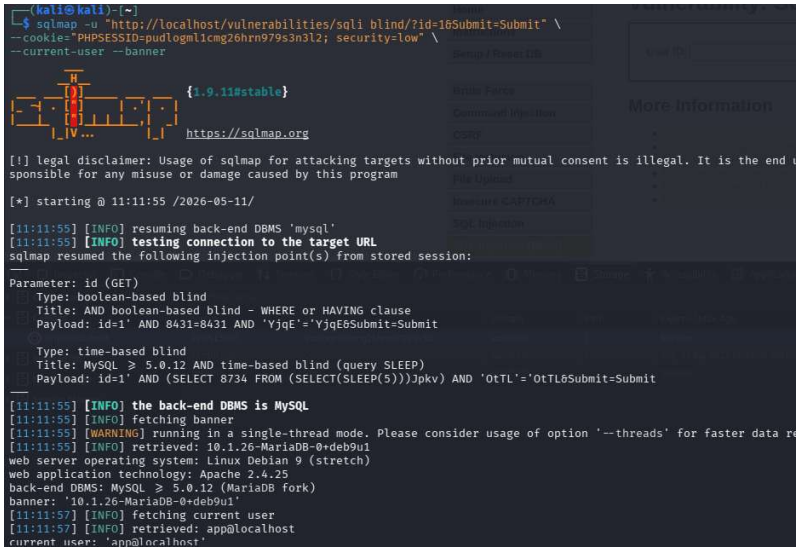
Zadanie 5

W kolejnym zadaniu naszym zadaniem jest wyciągnięcie informacji o nazwie użytkownika bazy danych, wersji MySQL oraz o katalogu MySQL. W tym celu możemy wykorzystać aplikację sqlmap który w naszym imieniu spenetruje bazę danych. To czego potrzebujemy to adres URL serwisu oraz wartość PHPSESSID.

Przy pomocy zapytania @@datadir możemy sprawdzić katalog z danymi SQL.



Przy pomocy –current-user –baner sprawdzamy nazwę użytkownika i wersję MySQL



Zadanie 6

Usuwamy kontener

